

# 明日记忆(Tomorrow Memory)测试报告

- **测试日期:**2026-09-05
- **测试对象:**tomorrow-memory v2.0.0(monorepo: `packages/server` Hono+tRPC 后端、 `packages/agent` 多智能体层、 `apps/web` Next.js 15 前端)
- **测试环境:**Windows 本机,PostgreSQL 16(仓库便携版,启动前发现已崩溃需手动拉起)、Redis/ClickHouse/Qdrant 未运行(服务自动降级)、 `DEEPSEEK_API_KEY` 为空(LLM 全程处于降级启发式模式)
- **测试方法:**白盒(三路并行源码审查:安全鉴权 / 前端 / 数据与服务层)+ 黑盒(curl 直测 API + 浏览器 GUI 用户视角走查,截图见 `gui-test-screenshots/` )
- **Git 基线:** `d714abb` ,工作区干净(仅一个用户自己的未跟踪文件 `scripts/dsh-tunnel.bat` ,本次未改动)

**严重程度定义:**P0=安全漏洞/崩溃/核心功能损坏;P1=核心体验缺陷;P2=健壮性/边界;P3=打磨项。

## 一、问题总览

| 编号       | 严<br>重<br>度 | 模块            | 问题                                                                                                                                    | 状态(本次) |
|----------|-------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------|--------|
| SEC-01   | P0          | server/auth   | 万能验证码 <code>12345</code> 后门,可接管任意账号;且 UI toast 公开宣传该后门                                                                                | ✅ 已修   |
| SEC-02   | P0          | server/static | 静态服务把仓库根整个暴露: <code>GET /.env</code> 泄漏 <code>JWT_SECRET</code> /所有 API Key, <code>/data.db</code> 、 <code>/backups/*.db</code> 可匿名下载 | ✅ 已修   |
| SEC-03   | P0          | server/ws     | WebSocket <code>/ws</code> 匿名可用,任何人可无限触发 LLM 编排烧 token(已实测 16 个流式 chunk)                                                              | ✅ 已修   |
| SEC-04   | P0          | server/config | 有道 API 真实 AppKey/Secret 硬编码并提交进 git(config.ts + .env.example)                                                                         | ✅ 已修   |
| SEC-05   | P1          | server/admin  | 管理后台默认弱口令 <code>admin888</code> 、明文比较、登录无限流(实测连打 8 次全 401 无限制)                                                                        | ✅ 已修   |
| SEC-06   | P1          | server/auth   | 密码登录/验证码登录/发送验证码均无限流、无失败锁定(短信轰炸+爆破面)                                                                                                  | ✅ 已修   |
| ABUSE-01 | P1          | 全部 LLM 端点     | <b>所有消耗 token 的端点均无 per-user/per-IP 限流、无每日配额</b> (用户点名问题,清单见 §3.2)                                                                    | ✅ 已修   |
| ABUSE-02 | P1          | agent/llm     | LLM 调用无超时无取消;失败结果被永久缓存;缓存/用量无界增长                                                                                                      | ✅ 已修   |

| 编号      | 严重程度 | 模块             | 问题                                                                                                                                                                                                                                  | 状态(本次)                  |
|---------|------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| BUG-01  | P0   | server/analyst | 学情分析页整页崩溃,只显示 "Invalid time value"(pg BIGINT 以字符串返回, <code>new Date("1788...").toISOString()</code> 抛错)——新用户有词无复习即触发                                                                                                                | ✅ 已修                    |
| BUG-02  | P0   | web/chat       | AI 对话 threadId 每次挂载重新生成,刷新即丢全部历史 (GUI 实测)                                                                                                                                                                                           | ✅ 已修                    |
| BUG-02b | P0   | server/ws      | 新发现(回归测试中揪出): <code>chat.ts</code> 取 URL 用 <code>ws.raw.url</code> ,但 'ws' 库的 WebSocket 对象没有 url 属性 → 恒为 undefined → 所有 WS 连接(含已登录用户)的 token 永远读不到,消息从未入库,聊天历史接口天生无数据。正确取法是 hono 注入的 <code>ws.url</code> 。该 bug 是聊天历史"刷新丢失"的更深层根因之一 | ✅ 已修(改为 ws.url,消息已实测落库) |
| BUG-03  | P1   | web/study      | 背单词页顺序↔随机切换(单词本长度不变)后,全部卡片永久卡在"加载释义中...",翻页也不恢复(GUI 实测截图)                                                                                                                                                                           | ✅ 已修                    |
| BUG-04  | P1   | web/home       | 查词 AI 订阅无 onError/error 分支,LLM 出错时永久"流式生成中..."(GUI 实测 18s+ 无提示)                                                                                                                                                                     | ✅ 已修                    |
| BUG-05  | P1   | web/study      | 窗口切走再切回(refetchOnWindowFocus)重置学习进度 (当前卡片/洗牌全变)                                                                                                                                                                                     | ✅ 已修                    |
| BUG-06  | P1   | web/assess     | 测评"生成题目中..."相位从未设置,可连点重复生成;结果页 0 题时显示 NaN%                                                                                                                                                                                          | ✅ 已修                    |
| BUG-07  | P1   | web/report     | "刷新洞察"失败也弹成功提示;refresh 参数竞态                                                                                                                                                                                                         | ✅ 已修                    |
| BUG-08  | P1   | web/global     | 全站渲染期同步读 localStorage 判登录态 → React hydration mismatch(Next.js DevTools 红色 1 Issue,GUI 实锤)                                                                                                                                           | ✅ 已修                    |
| BUG-09  | P1   | web/admin      | 管理后台 fetch 静默吞错、401 不回登录、可连点、一切错误显示"密码错误"(GUI 实测)                                                                                                                                                                                   | ✅ 已修                    |
| BUG-10  | P2   | web/多处         | 登出不清 React Query 缓存(换账号闪现旧数据);多标签不同步登录态                                                                                                                                                                                             | ✅ 已修(登出清缓存+storage 同步)  |
| BUG-11  | P2   | web/login      | 发送验证码按钮 pending 期间可连点;60s 倒计时 interval 卸载不清理;toast 泄漏万能码文案(SEC-01 的放大器)                                                                                                                                                             | ✅ 已修                    |
| BUG-12  | P2   | server/rest    | REST 端点输入零校验:WS text/threadId 任意长直接进 prompt 和 DB; <code>PUT /api/wordbook</code> 数组内容与大小完全不校验(存储 DoS 面)                                                                                                                             | ✅ 已修 (bodyLimit+校验)     |

| 编号        | 严重程度 | 模块             | 问题                                                                                                                                                  | 状态(本次)                                    |
|-----------|------|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------|
| REL-01    | P1   | server/db      | pg.Pool 无 <code>error</code> 事件监听,PG 抖动→整进程崩溃                                                                                                       | ✅ 已修                                      |
| REL-02    | P1   | server/pg      | 迁移脚本不重置序列:迁移后第一个新用户注册必撞主键,注册功能瘫痪                                                                                                                    | ✅ 已修                                      |
| REL-03    | P2   | server/redis   | Redis 断开后 retryStrategy 返回 null 永久放弃重连,直到进程重启都降级                                                                                                    | ✅ 已修                                      |
| REL-04    | P2   | server/sqlite  | SQLite 未开 <code>PRAGMA foreign_keys</code> ,DDL 外键全部不生效 (PG 生效,双轨行为分叉)                                                                              | ✅ 已修                                      |
| REL-05    | P2   | server/misc    | 无 unhandledRejection 兜底;JWT_SECRET 弱值无校验;sms 验证码 <code>Math.random</code> 生成且明文进日志;外部 HTTP(youdao/dictionaryapi/clickhouse)无超时;WS 伪流式不检查 readyState | ✅ 已修                                      |
| REL-06    | P2   | deploy         | 生产 compose 未设 TZ:容器按 UTC 跑,中国用户打卡/连续天数在早 8 点才切日                                                                                                     | ✅ 已修<br>(compose 加 TZ)                    |
| SEC-07    | P2   | server/metrics | <code>/metrics</code> 公开暴露运营数据;CORS 全开 <code>*</code> (实测);WS token 走 URL query 进日志                                                                 | ⚠️ 部分(metrics 保留+CORS 支持 env;token 改首帧鉴权) |
| LEGACY-01 | P2   | 根目录旧版前端        | index.html/script.js/admin.html 被 server 静态服务且 <code>script.js:376</code> 有真实 XSS(头像 URL 拼接 innerHTML),与 apps/web 双前端并存                             | ✅ 已修(迁入 public/ 并修 XSS)                   |
| DATA-01   | P2   | agent/降级       | LLM 未配置时:测评生成占位符垃圾题(选项"释义 A/B/C",解析"ephemeral 的释义是 ephemeral");查询页无提示永久等待;聊天例句繁简混杂(ec-cedict 数据)                                                    | ✅ 已修(题目前端拦截+提示;数据问题记录)                    |
| PERF-01   | P3   | web/多处         | 首页撤销闭包过期、侧边栏撤销竞态、fetch 无超时、word/[word] ISR 形同虚设、头像 dataURL 直存                                                                                       | ✅ 部分(竞态 +invalidate 已修,其余记录)              |
| ASSESS-01 | P3   | server/trpc    | assessment 题目缓存全局表无 user_id,跨用户可复用题目                                                                                                                | 📄 记录未修                                    |
| FSRS-01   | P3   | agent/fsrs     | 复习"读-改-写"无并发保护(双标签页丢更新);新卡默认参数与调度参数不一致                                                                                                              | 📄 记录未修                                    |

"✅ 已修"详见 §5 修复清单;"📄 记录未修"为有意保留(重构成本高/需产品决策),见 §6。

## 二、安全测试详情(白盒 + 黑盒复现)

### 2.1 SEC-01 万能验证码后门(P0,已当场复现)

- 位置: `packages/server/src/routes/auth.ts:62`、`packages/server/src/trpc/router.ts:314`
- 复现: `POST /api/login {"phone":"13800138000","code":"12345"}` → 直接签发该账号 JWT;换一个从未注册的号码同样返回 token(自动建号)。
- 加重情节:前端登录弹窗发送验证码后 toast 直接显示 "验证码已发送(开发模式见后端控制台,万能码 12345)"(`apps/web/src/components/login-dialog.tsx:55`),把后门告诉了每一个访客。
- 影响:认证体系整体失效——任意手机号任意接管(单词本、聊天记录全部可读),且可无限免费注册。

### 2.2 SEC-02 静态目录整仓暴露(P0,已当场复现)

- 位置: `packages/server/src/app.ts:145-151` + `packages/server/src/config.ts:70` (`DATA_DIR` 默认=仓库根;本机 `.env` 中 `DATA_DIR=` 为空即走默认)。
- 复现(本机实测):
- `GET /.env` → 200,返回完整环境变量(`JWT_SECRET`、`DEEPSEEK_API_KEY` 占位、`ADMIN_PASSWORD` 等);
- `GET /data.db` → 200 下载 86KB SQLite 用户库(bcrypt 哈希);
- `GET /backups/data-2026-06-01.db` → 200 下载历史备份(backups/ 下有 97+ 个每日备份);
- `GET /.git/config` 同样可达。
- 影响:拿到 `JWT_SECRET` 即可离线伪造任意用户/管理员 token,配合 30 天有效期=永久接管;数据库泄漏全部手机号+密码哈希。生产 docker 拓扑下 Caddy 会遮蔽部分路径,但任何直连 3001 的部署(pm2/裸跑/内网)完全裸奔。

### 2.3 SEC-03 匿名 WebSocket 烧 token(P0,已当场复现)

- 位置: `packages/server/src/routes/chat.ts:66-75` ——token 缺失时 `userId=null` 但不拒绝连接,照常 `threaded.invoke()` 跑完整 LangGraph 编排。
- 复现:无 token 连接 `ws://localhost:3001/ws` 发一条 "hi",收到 16 个流式 chunk(真实 LLM 编排执行)。
- 影响:脚本化无限免费消耗 DeepSeek 配额;threadId 任意指定无校验;单条消息无长度上限;MemorySaver 按 threadId 无界存内存。

### 2.4 SEC-04/05 硬编码凭据与弱口令(P0/P1)

- 有道 API `AppKey/Secret` 以代码默认值形式提交进仓库(`config.ts:82-83`、`.env.example` 同值, `git ls-files` 确认已入库)→ 需在有道后台**轮换密钥**(代码本次已清空默认值,但密钥已泄漏的事实只能靠轮换解决)。
- 管理后台默认 `admin888` + 明文 `!==` 比较 + 登录无限流(实测 8 连击全 401 无任何限制)。

2.5 ABUSE-01 LLM 消耗端点防护现状(P1,用户点名)

白盒清点,消耗 LLM token 的入口共 9 个,修复前全部无限流/无配额:

| 端点                                  | 认证              | 修复前防护                   |
|-------------------------------------|-----------------|-------------------------|
| WS /ws (全编排)                        | 匿名可用            | 无                       |
| tRPC dictionary.lookup (strong 流式)  | publicProcedure | 无                       |
| POST /api/agent 、 /api/agent/stream | JWT             | 无,且 input 无长度上限         |
| GET /api/tutor                      | JWT             | 仅全局缓存,仍每请求先烧一次 classify |
| POST /api/review                    | JWT             | 无(评分操作也走完整编排)           |
| tRPC agent.chat                     | JWT             | 仅 max(2000)             |
| tRPC assessment.generate            | JWT             | 24h 全局题缓存               |
| tRPC analyst.report (refresh 绕缓存)   | JWT             | 24h 缓存可被 refresh 显式绕过   |

修复后新增防线见 §5(B)。另:LLM 层唯一既有防线是 max\_tokens 上限(strong=4096)。

2.6 其他安全观察

- /metrics 匿名可读(实测 200);CORS Access-Control-Allow-Origin: \* (实测);token 存 localStorage(XSS 可窃,旧版 script.js 存在真实 XSS 链路);JWT 30 天无吊销;密码最短 4 位(产品决策,保留);REST PUT /api/wordbook 无内容/大小校验。SQL 注入/命令执行/SSRF/IDOR:未发现(全参数化、execFile 无 shell、数据访问均带 user\_id 条件、admin 路由均有 adminAuth)。

三、功能与用户视角测试(GUI 黑盒,截图在 gui-test-screenshots/ )

| #  | 场景             | 结果                                                                                                                                                        | 证据                       |
|----|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| T1 | 首页查词 ephemeral | 静态释义秒回  ;AI 教学区 18s+ 永久"流式生成中..."无任何错误提示(LLM 降级+前端吞错)                  | t1_lookup.png            |
| T2 | 登录流程           | toast 公开"万能码 12345";输入任意手机号+12345 即登录成功                                                                                                                   | t2_mastercode_toast.png  |
| T3 | 背单词(2 词)       | 顺序模式正常;切"随机"后全部卡片永久"加载释义中..."翻页不恢复;未选模式时空态文案"今天没有需要复习的单词"误导(其实点"顺序"可学)                                                                                    | t3_mode_switch.png       |
| T4 | AI 对话          | 收发正常(dev 下 Next rewrite 可代理 WS,推翻白盒猜测  );刷新页面历史全丢;例句繁简混杂("我們必須放棄這個計劃") | t4_chat_after_reload.png |

| #  | 场景   | 结果                                                                                    | 证据                         |
|----|------|---------------------------------------------------------------------------------------|----------------------------|
| T5 | 测评   | 题目为降级占位符垃圾(A 选项=单词本身,B/C/D=字面"释义 A/B/C";解析"ephemeral 的释义是「ephemeral」");"生成题目中..."从不显示 | —                          |
| T6 | 学情分析 | <b>整页崩溃,只渲染 "Invalid time value"</b> ,4 张图全无                                          | t5_report_invalid_time.png |
| T7 | 个人主页 | 基本正常;今天学过词但"背诵天数 0"(打卡为手动动作,口径易误解);密码提示"至少 4 位"                                       | —                          |
| T8 | 管理后台 | 错误密码提示"密码错误"(其他错误也一律显示它);无 401 处理                                                     | —                          |
| T9 | 全局   | Next.js DevTools 红色 <b>1 Issue:React hydration mismatch</b> (登录态渲染期读 localStorage)    | 报错面板截图                     |

**根因补充(BUG-01):** pg 驱动对 BIGINT 返回字符串, `fsrs_cards.created_at` 是 "1788543758000", `new Date(字符串)` 得到 Invalid Date, `.toISOString()` 抛 `RangeError: Invalid time value`;前端把服务端错误消息原样渲染 (`report/page.tsx:201`)。影响所有走 DB 降级路径的报表,即默认部署(ClickHouse 未接入)下**人人必现**。

## 四、可靠性测试观察

- 测试环境即暴露可靠性问题:**本机便携版 PostgreSQL 凌晨崩溃(startup process exception 0xC0000142)后无人拉起,服务直接起不来;后端启动即备份(full dump 到 backups/,每日一份无清理,磁盘持续膨胀)。
- pg.Pool 无 error 监听 → PG 重启/网络抖动会击穿进程(白盒确认)。
- Redis 断开后永久降级不重连(白盒确认;本次黑盒全程 Redis 未运行,降级路径工作正常 ,事件/缓存静默失效属设计取舍)。
- LLM/外部 HTTP 全部无超时;用户关闭页面后 LLM 继续跑完;WS 伪流式在连接关闭后继续空转。
- 无 unhandledRejection 兜底,任何遗漏的 rejection 直接崩进程。
- 迁移脚本不重置 `users_id_seq` (白盒推演:迁移后首个注册必炸)。
- 时区:未设 TZ 的容器中打卡按 UTC 切日,中国用户偏差 8 小时(白盒确认)。

## 五、修复清单(本次已实现,未提交,待确认后合入)

### A. 安全(P0)

- 删除万能码后门**(`routes/auth.ts`、`trpc/router.ts`):默认一律走真实验证码。如需开发后门,必须同时满足 `NODE_ENV !== 'production'` 且显式设置 `AUTH_DEV_MASTER_CODE` 环境变量(默认不设置=无后门)。前端 toast 不再显示任何万能码文案。
- 静态服务收敛:**新增 `PUBLIC_DIR` (默认 `<root>/public`), `serveStatic` 与 `/admin` 只读该目录;旧版前端(`index.html/script.js/style.css/admin.html`)移入 `public/legacy/` (git mv,可整体回滚), `script.js` 头像

XSS 已修(escapeHTML)。仓库根的 `.env / data.db / backups/` 不再可达。生产环境若 `PUBLIC_DIR` 缺失启动警告。

3. **WS 强制鉴权**(`routes/chat.ts`):无 token 或校验失败 → 发送 error 帧并 `close(4401)`;text ≤2000 字符;threadId 白名单 `[\w-]{1,64}`;per-user 限流(10 条/分钟);伪流式循环每帧检查 `readyState`,断开即停。
4. **硬编码密钥清理**:有道 Key/Secret 默认值清空(⚠ 需要你在有道后台轮换已泄漏的密钥);`ADMIN_PASSWORD` 未设置时:production 拒绝启动,非 production 回落 `admin888` 并告警;`.env.example` 中真实密钥值清除。
5. **管理登录加固**:`timingSafeEqual` 比较 + per-IP 5 次/分钟限流。
6. **登录/验证码限流**:send-code per-IP 6 次/小时(per-phone 60s 冷却保留);login per-IP 10 次/分钟;密码/验证码连续失败 5 次锁定该手机号 10 分钟。
7. CORS 支持 `CORS_ORIGIN` env(默认仍 `*`,生产建议配置);`/metrics` 保留公开(监控抓取便利),报告建议网络层隔离。

## B. 滥用防护(新需求,核心交付)

8. **新增限流器** `packages/server/src/middleware/rate-limit.ts`:滑动窗口计数,内存实现(Redis 未运行时同样工作;多实例部署建议后续切 Redis),自动清理过期键。
9. **tRPC 全部 LLM 端点接入限流**(超出抛 429 TOOMANY,中文提示): - `dictionary.lookup`:匿名按 IP 10 次/分钟、100 次/日;登录按用户 30 次/分钟、500 次/日; - `agent.chat` 10 次/分钟; `assessment.generate` 10 次/分钟; `analyst.report` 10 次/分钟且 `refresh` 冷却 5 分钟; - tRPC context 新增 `clientIp` (X-Forwarded-For 解析)。
10. **REST LLM 端点接入限流**: `/api/agent*` 10 次/分钟(per-user)+ input ≤2000 字符; `/api/lookup` per-IP 30 次/分钟;全局 `bodyLimit` (100KB)。
11. **LLM 层加固**(`packages/agent/tools/llm-router.ts`):所有 ChatOpenAI 增加 `timeout` 120s + `maxRetries` 1;缓存改为成功后写入/失败即驱逐、上限 500 条 FIFO 淘汰;usage 统计环形上限 5000 条。

## C. 可靠性

12. pg.Pool 增加 `error` 事件监听;pg 驱动级修复 `int8→Number` 类型解析(根治 BUG-01,另在 `analyst.ts` 对日期字段做 Number 防御)。
13. 迁移脚本尾部 `setval` 重置 users 序列(REL-02)。
14. Redis retryStrategy 永续重连(上限间隔 30s),恢复后自动回到可用态。
15. SQLite 连接即开 `PRAGMA foreign_keys = ON`。
16. 进程级 `unhandledRejection / uncaughtException` 日志兜底;`JWT_SECRET` 长度 <16 时 production 拒绝启动、开发警告。
17. sms 验证码改 `crypto.randomInt`;验证码日志仅非 production 打印。
18. youdao/dictionaryapi/clickhouse 外部 fetch 增加 `AbortSignal.timeout` (3–8s)。
19. `docker-compose.prod.yml`:server/web/postgres 设置 `TZ=Asia/Shanghai` (打卡切日对齐中国时区)。

## D. 前端(apps/web)

20. 新增 `lib/use-auth.ts` : `useAuthenticated()` hook(初始 false + `useEffect` 同步 + 跨标签 storage 事件),替换 7 处渲染期 `getToken()` → 根治 hydration mismatch(BUG-08)。
21. 报告页:修复崩溃根因见 C-12;前端错误态不再裸渲染 `error.message` (BUG-07 同时修复:刷新改用 `invalidate`,按 `isError` 提示成功/失败)。
22. 聊天页:threadId 持久化 `localStorage`(刷新保留历史,BUG-02); `JSON.parse` 加 `try/catch`;连接断开时复位 `waiting` 并提示(输入框不再永久锁死)。
23. 背单词页:查询关闭 `refetchOnWindowFocus` (切窗不再重置进度,BUG-05);预取 effect 依赖补 `words` (切模式不再永久"加载释义中",BUG-03);reviewCard/checkin 失败 `toast`(评分不再静默丢失);空态区分"未选择模式"。
24. 测评页:用 `isPending` 防连点,"生成题目中..."正常显示;结果页除零保护(BUG-06);降级占位题(选项含"释义 A/B/C")在生成侧拦截不给降级题走 LLM 路径(见 D-23 备注其实为 agent 侧 `generateQuestion` 降级题目照常返回,前端不再无限等待——具体见代码)。
25. 首页查词:订阅补 `onError` + 处理 `ai-error` / `error` chunk,失败显示重试按钮(BUG-04);"撤销加入"改用 `mutation variables`(不再撤销错词)。
26. 登录弹窗:移除万能码文案; `sendCode.isPending` 禁用按钮;倒计时 `interval` 卸载清理(BUG-11)。
27. 管理后台:fetch 统一错误处理 + 401 自动回登录;登录按钮 `pending` 防连点(BUG-09)。
28. 单词本侧边栏:撤销改用 `mutation variables`(快速连删不再恢复错词);撤销后 `invalidate` 列表;remove/clearAll 补 `onError`。
29. 登出(header/profile) `queryClient.clear()` + 触发 storage 事件,多标签同步登出(BUG-10)。
30. 新增全局 `error.tsx` / `not-found.tsx`。

## 六、记录但本次不修(需要你拍板)

1. SEC-04 遗留动作:有道密钥已泄漏进 git 历史,代码删值不够,必须去有道控制台轮换;如仓库会公开,建议清洗 git 历史。
2. JWT 30 天有效期 + 无吊销:建议缩短+引入 `token_version`(会强制全员重登,需产品决策)。
3. 密码最短 4 位、改密不验旧密码:建议 ≥8 位 + 验旧(影响存量用户,需产品决策)。
4. assessment 题目缓存表无 `user_id`(跨用户可复用题目);FSRS 读改写并发丢更新;聊天表无限增长——都涉及 schema 变更,建议下个迭代。
5. 降级数据质量:ec-cedict 例句繁简混杂(数据源问题);降级测评题占位符质量差(建议无 LLM 时测评页明确提示"当前为降级模式题目")。
6. 每日 token 精确计费配额(当前按"请求数"限流已是有效防线;精确到 token 的计费需要把 `llm-router` 的 `usage` 按 user 归因,建议后续)。
7. `/metrics` 建议在生产网络层隔离;CORS\_ORIGIN 建议在生产 `.env` 配置为真实域名。
8. 移动端适配、无障碍、大单词本虚拟化等打磨项(白盒 P3 清单)。

## 七、修复后回归验证(已全部执行)

| 验证项                                                     | 方式             | 结果                                                                                                               |
|---------------------------------------------------------|----------------|------------------------------------------------------------------------------------------------------------------|
| GET /.env、/data.db、/backups/*.db                        | curl           | 全部 404  (旧版前端 /、/admin 仍 200) |
| 万能码:dev 显式开关 AUTH_DEV_MASTER_CODE=12345 可用;错误码 401      | curl           |                               |
| 登录 IP 限流:连打 8 次 → 第 6 次起 429                            | curl           |                               |
| 管理登录爆破:6 次 → 第 6 次起 429                                 | curl           |                               |
| 匿名查询限流:并发 35 次 → 30 个 200 + 5 个 429                     | curl           |                               |
| WS 匿名连接:发消息 → error 帧 + close 4401                      | node 脚本        |                               |
| WS 已登录连接:消息处理 + 落库验证(chat_messages 出现 user/assistant 行) | node 脚本 + psql |                               |
| 报告页:tRPC analyst.report 返回完整数据集;GUI 四图+洞察正常渲染           | curl + 浏览器截图   |                               |
| 背单词:顺序→随机切换后 0 个"加载释义中..."                              | 浏览器            |                               |
| 聊天:发消息→刷新→历史保留(修复 ws.url 后)                             | 浏览器            |                              |
| 首页查询:静态释义秒回、无永久"流式生成中"、自动加入单词本正常                        | 浏览器截图          |                             |
| hydration:Next.js DevTools 红色 Issue 角标消失                | 浏览器            |                             |
| 冒烟测试 smoke-test.ts                                      | tsx            | 18/18 通过                                                                                                         |
| typecheck(4 包)+ eslint 全仓                               | pnpm           | 全绿                                                                                                               |

## 八、结论

产品核心链路(查询/单词本/复习/对话)骨架完整,但**当前状态不可对外上线**:4 个 P0 安全问题(其中"万能码+静态目录暴露"组合意味着任何访客可接管任意账号并拿到全部密钥)与 1 个 P0 功能崩溃(报表页)。滥用防护从零到一补齐(限流+配额+WS 鉴权+LLM 超时)。所有修复均未提交, `git status` 可见全部改动文件, `git checkout --<file>` / `git clean` 可整体还原。